

IntelliDent — Database Schema Documentation

Project: IntelliDent **Stack:** PostgreSQL + Prisma ORM **Architecture:** Multi-tenant, Zero Trust, Client-Side E2EE **Team:** BS Information Technology (Cybersecurity) — FEU Institute of Technology

Overview

IntelliDent uses a relational PostgreSQL database managed via Prisma ORM. The schema is designed around three core principles:

- Multi-Tenancy** — Every table includes a `clinicId` to logically isolate data between the three partner clinics. No query should ever return data across clinics.
- Soft Deletes** — No record is ever permanently deleted. Every model has `isDeleted` `Boolean @default(false)` and `deletedAt` `DateTime?` . This preserves audit trails and supports data recovery.
- Zero Trust** — Every access point verifies session, role, and clinic scope before executing a query. All sensitive data fields are encrypted client-side before reaching the server.

Enums

Enums define the allowed values for status and category fields across the schema.

Enum	Values	Used In
UserRole	PATIENT, STAFF, ADMIN	User
Gender	MALE, FEMALE, OTHER, PREFER_NOT_TO_SAY	Patient
AppointmentStatus	PENDING, CONFIRMED, RESCHEDULED, CANCELLED, COMPLETED, NO_SHOW	Appointment
RecordStatus	ACTIVE, ARCHIVED	PatientRecord
PaymentStatus	UNPAID, PARTIAL, PAID, REFUNDED	Billing
NotificationStatus	PENDING, SENT, FAILED	Notification
AuditAction	LOGIN, LOGOUT, CREATE, UPDATE, DELETE, VIEW, EXPORT, VERIFY	AuditLog
ConsentStatus	PENDING, GIVEN, REVOKED	Patient

Models

Clinic

The root of the multi-tenant system. Every other model is scoped to a clinic via `clinicId` .

Field	Type	Description
id	String (cuid)	Primary key — URL-safe unique ID
name	String	Clinic display name

address	String?	Physical address
phone	String?	Contact number
email	String?	Contact email
isDeleted	Boolean	Soft delete flag
createdAt	DateTime	Record creation timestamp
updatedAt	DateTime	Last modified timestamp
deletedAt	DateTime?	Soft delete timestamp

Relations: has many `User` , `Staff` , `Patient` , `Service` , `Appointment` , `AuditLog`

User

Handles authentication and account management. Linked to either a `Patient` or `Staff` profile depending on the role.

Field	Type	Description
id	String (cuid)	Primary key
email	String	Unique login identifier
name	String?	Display name
password	String	bcrypt-hashed password
role	UserRole	Access level: PATIENT, STAFF, ADMIN
wrappedKey	String?	AES-GCM master key wrapped with PBKDF2-derived KEK
keySalt	String?	PBKDF2 salt used to derive the KEK (base64)
clinicId	String?	Tenant scope
isDeleted	Boolean	Soft delete flag
createdAt	DateTime	Record creation timestamp
updatedAt	DateTime	Last modified timestamp
deletedAt	DateTime?	Soft delete timestamp

E2EE Note: `wrappedKey` and `keySalt` are part of the client-side encryption system. The server stores only the encrypted (wrapped) version of the master key. It cannot decrypt it — only the user's browser can, using their password. Even with full database access, developers cannot read user data.

Patient

Extended profile for users with the `PATIENT` role. Stores personal and consent information.

Field	Type	Description
-------	------	-------------

id	String (cuid)	Primary key
userId	String	One-to-one link to User
clinicId	String	Tenant scope
firstName	String	Patient first name
lastName	String	Patient last name
dateOfBirth	DateTime?	Date of birth
gender	Gender?	Gender identity
phone	String?	Contact number
address	String?	Home address
consentStatus	ConsentStatus	Consent tracking (RA 10173 compliance)
consentGivenAt	DateTime?	When consent was recorded
isDeleted	Boolean	Soft delete flag
createdAt	DateTime	Record creation timestamp
updatedAt	DateTime	Last modified timestamp
deletedAt	DateTime?	Soft delete timestamp

Relations: has many Appointment , PatientRecord , Billing , Notification

Staff

Extended profile for users with the STAFF role (dentists, clinic personnel).

Field	Type	Description
id	String (cuid)	Primary key
userId	String	One-to-one link to User
clinicId	String	Tenant scope
specialty	String?	Dental specialty or position
isDeleted	Boolean	Soft delete flag
createdAt	DateTime	Record creation timestamp
updatedAt	DateTime	Last modified timestamp
deletedAt	DateTime?	Soft delete timestamp

Relations: has many Appointment (as dentist)

Service

Dental services offered by a clinic (e.g., cleaning, extraction, braces). Linked to appointments for duration and pricing.

Field	Type	Description
id	String (cuid)	Primary key
clinicId	String	Tenant scope
name	String	Service name
description	String?	Optional description
duration	Int	Estimated duration in minutes — used by AI scheduler
price	Float	Service price
isDeleted	Boolean	Soft delete flag
createdAt	DateTime	Record creation timestamp
updatedAt	DateTime	Last modified timestamp
deletedAt	DateTime?	Soft delete timestamp

Appointment

Core scheduling model. Links a patient, dentist, service, and clinic to a time slot.

Field	Type	Description
id	String (cuid)	Primary key
clinicId	String	Tenant scope
patientId	String	Linked patient
dentistId	String	Assigned staff/dentist
serviceId	String	Dental service being performed
scheduledAt	DateTime	Appointment start time
endsAt	DateTime	Appointment end time (calculated from service duration)
status	AppointmentStatus	Current status
notes	String?	Optional notes
aiSuggested	Boolean	Whether this slot was suggested by GPT-5
isDeleted	Boolean	Soft delete flag
createdAt	DateTime	Record creation timestamp

updatedAt	DateTime	Last modified timestamp
deletedAt	DateTime?	Soft delete timestamp

Relations: has one `Billing` , has many `Notification`

PatientRecord

Stores treatment history, notes, and clinical data. All sensitive content is E2EE encrypted before being stored.

Field	Type	Description
id	String (cuid)	Primary key
patientId	String	Linked patient
clinicId	String	Tenant scope
title	String	Record title (unencrypted, for listing)
encryptedData	String?	AES-GCM encrypted content blob
dataIv	String?	Initialization vector for decryption
contentHash	String?	SHA-256 hash for tamper detection
status	RecordStatus	ACTIVE or ARCHIVED
isDeleted	Boolean	Soft delete flag
createdAt	DateTime	Record creation timestamp
updatedAt	DateTime	Last modified timestamp
deletedAt	DateTime?	Soft delete timestamp

Tamper Detection: `contentHash` stores a SHA-256 hash of the original plaintext. On read, the decrypted content is re-hashed and compared. Any mismatch indicates tampering.

Relations: has many `Attachment`

Attachment

Files associated with a patient record — X-rays, before/after photos, etc.

Field	Type	Description
id	String (cuid)	Primary key
recordId	String	Linked patient record
fileName	String	Original file name
fileUrl	String	Storage URL (encrypted cloud storage)

contentType	String	File type (e.g., image/png, application/pdf)
isDeleted	Boolean	Soft delete flag
createdAt	DateTime	Record creation timestamp
updatedAt	DateTime	Last modified timestamp
deletedAt	DateTime?	Soft delete timestamp

Billing

Tracks charges and payment status per appointment.

Field	Type	Description
id	String (cuid)	Primary key
clinicId	String	Tenant scope
patientId	String	Linked patient
appointmentId	String	One-to-one with Appointment
amount	Float	Total amount charged
amountPaid	Float	Amount paid so far
balance	Float	Remaining balance
status	PaymentStatus	Payment state
receiptNumber	String?	Unique receipt identifier
isDeleted	Boolean	Soft delete flag
createdAt	DateTime	Record creation timestamp
updatedAt	DateTime	Last modified timestamp
deletedAt	DateTime?	Soft delete timestamp

Relations: has many Payment

Payment

Individual payment transactions against a billing record.

Field	Type	Description
id	String (cuid)	Primary key
billingId	String	Linked billing record
amount	Float	Amount paid in this transaction

method	String?	Payment method (cash, GCash, card, etc.)
notes	String?	Optional notes
paidAt	DateTime	When the payment was made
isDeleted	Boolean	Soft delete flag
createdAt	DateTime	Record creation timestamp
updatedAt	DateTime	Last modified timestamp
deletedAt	DateTime?	Soft delete timestamp

Notification

Email notifications sent to patients for appointment reminders and updates.

Field	Type	Description
id	String (cuid)	Primary key
clinicId	String	Tenant scope
patientId	String	Recipient patient
appointmentId	String?	Related appointment (optional)
status	NotificationStatus	PENDING, SENT, or FAILED
subject	String?	Email subject line
message	String	Email body
scheduledAt	DateTime?	When it should be sent
sentAt	DateTime?	When it was actually sent
isDeleted	Boolean	Soft delete flag
createdAt	DateTime	Record creation timestamp
updatedAt	DateTime	Last modified timestamp
deletedAt	DateTime?	Soft delete timestamp

AuditLog

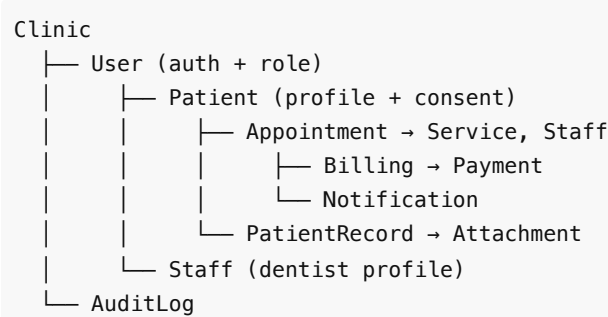
Append-only log of all system actions. No `updatedAt` or soft delete — audit records are permanent.

Field	Type	Description
id	String (cuid)	Primary key
userId	String?	Who performed the action

clinicId	String?	Which clinic context
action	AuditAction	Action type
entity	String	Model name (e.g., "Appointment")
entityId	String?	ID of the affected record
ipAddress	String?	Request IP address
userAgent	String?	Browser/device info
metadata	Json?	Additional context (diff, old values, etc.)
createdAt	DateTime	When the action occurred

Note: *AuditLog is intentionally append-only. It has no `isDeleted`, `updatedAt`, or `deletedAt` fields — audit records must never be modified or removed.*

Entity Relationship Summary



Security Design Notes

Zero Trust Verification Flow

Every data request goes through this chain before executing:

```
Request received
→ Is session valid?
→ What is the user's role?
→ Does the clinicId match the requested resource?
→ Does the role have permission for this action?
→ Execute tenant-scoped query
→ Log the access attempt (success or failure) to AuditLog
```

Client-Side E2EE Flow

```
Registration:
password → PBKDF2 (150,000 iterations) → KEK
generateMasterKey() → AES-GCM-256 key
wrapMasterKey(masterKey, KEK) → wrappedKey (base64)
```

→ server stores: wrappedKey + keySalt only

Login:

server returns: wrappedKey + keySalt

password + salt → PBKDF2 → KEK

unwrapMasterKey(wrappedKey, KEK) → masterKey (in memory only)

Data write:

encryptData(masterKey, plaintext) → { ciphertext, iv }

→ server stores: ciphertext + iv only

Data read:

server returns: ciphertext + iv

decryptData(masterKey, ciphertext, iv) → plaintext (browser only)

Compliance Alignment

Standard	How It's Addressed
RA 10173 (Data Privacy Act)	Consent tracking on Patient, E2EE for sensitive data, soft deletes for right-to-erasure
ISO/IEC 27001	AuditLog on all actions, RBAC, tamper detection via contentHash
NIST CSF	Identify (roles/assets), Protect (E2EE, RBAC), Detect (AuditLog, tamper hash), Respond (status flags), Recover (soft deletes)